

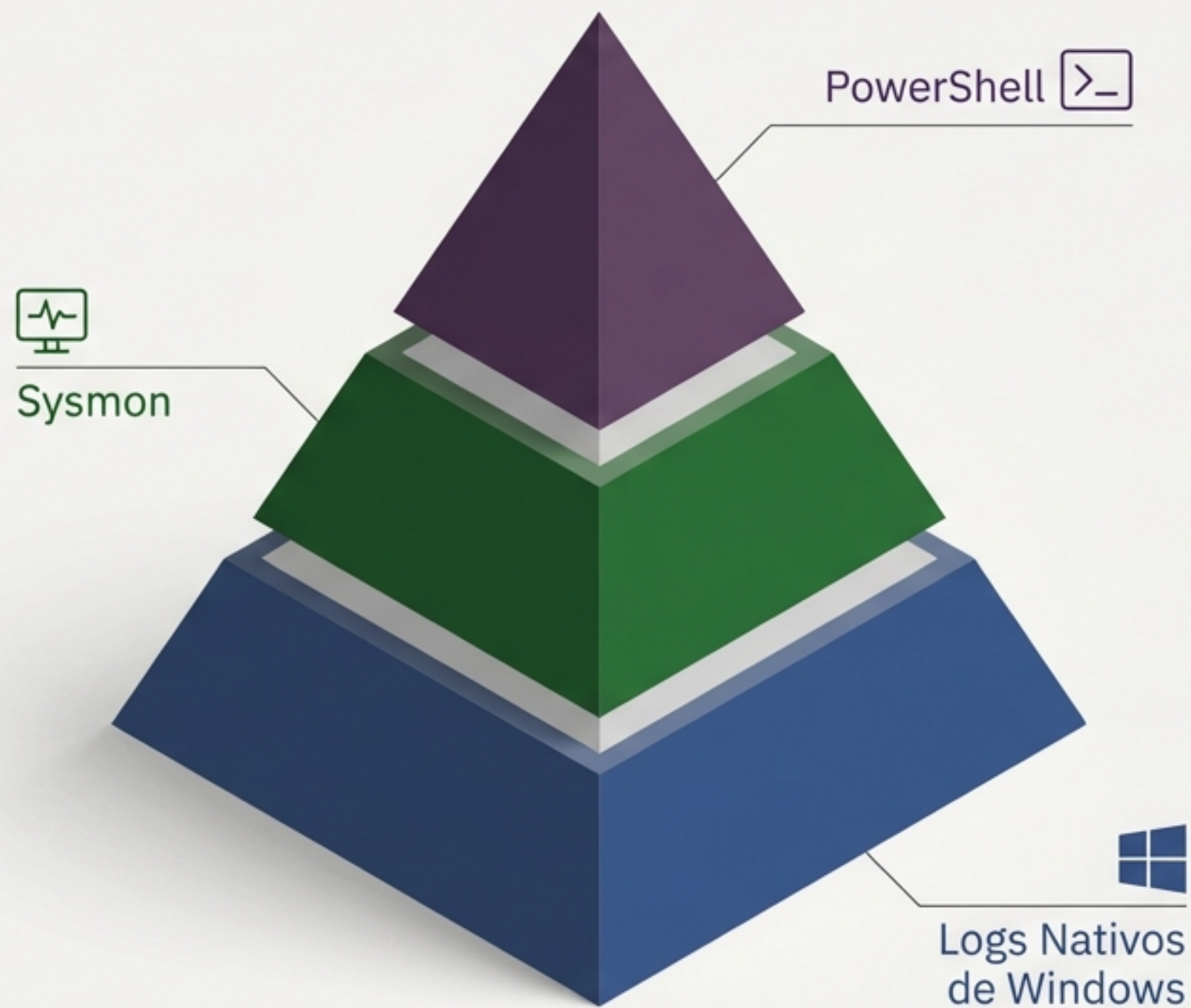
De los Logs Básicos a la Detección Avanzada

Una Guía Esencial para Dominar la
Visibilidad en Entornos Windows

El Log: La Piedra Angular del Analista de SOC

El tiempo de un analista se invierte en el triaje de alertas y la identificación de amenazas. Los logs son la materia prima de este trabajo. Un registro adecuado es fundamental para:

- 🕒 **Respuesta a Incidentes:** Muestran cuándo y cómo ocurrió un ataque.
- 🔍 **Threat Hunting:** Permiten buscar activamente señales de actividad maliciosa.
- 🔔 **Alertas y Triage:** Son la base de cualquier regla de detección.



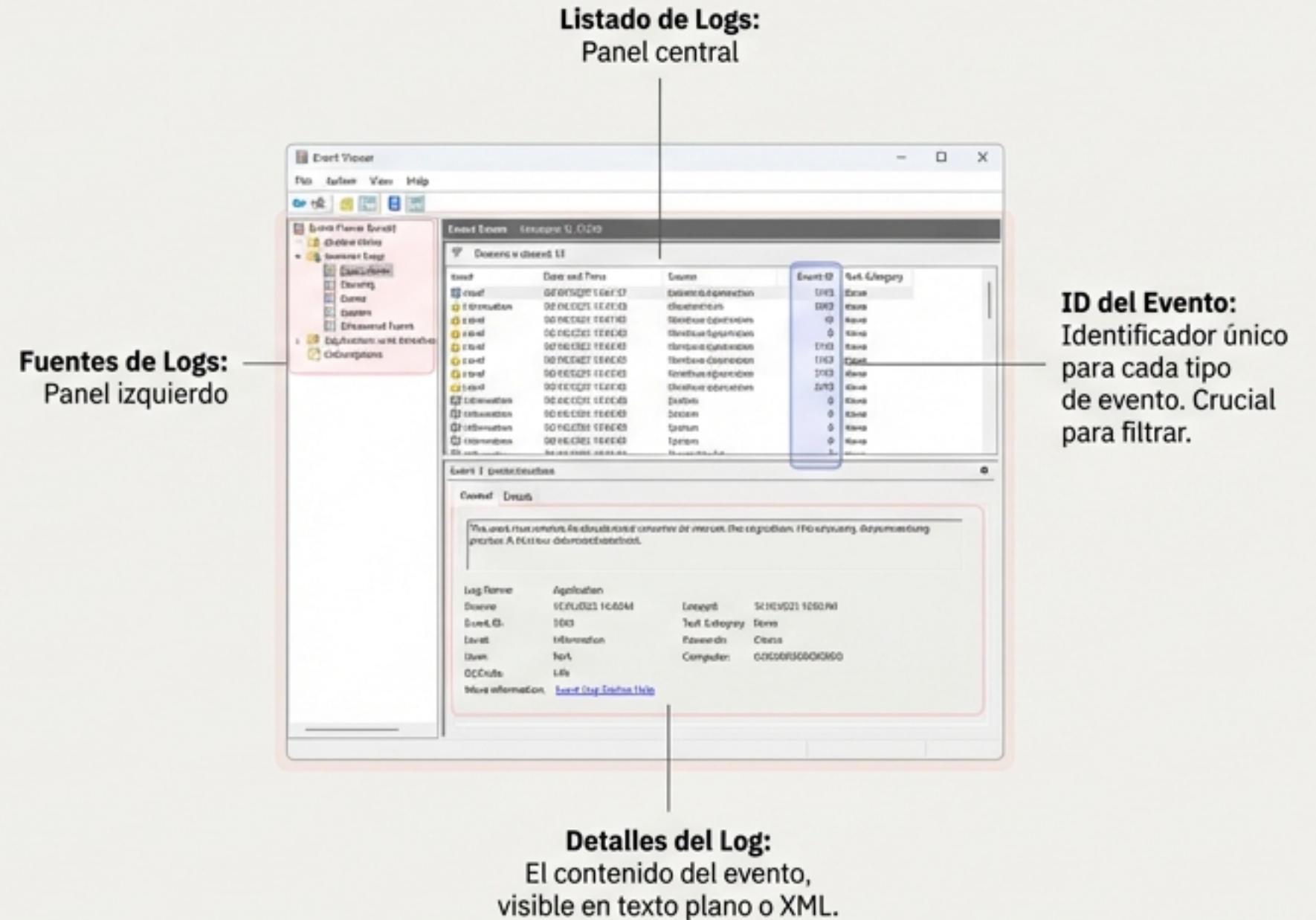
Anatomía de un Evento de Windows

¿Dónde se guardan?: Los logs se almacenan en formato binario (`.evtx`) en la ruta `C:\Windows\System32\winevt\Logs`.

¿Cómo se leen?: La herramienta nativa es el **Visor de Eventos (Event Viewer)**.

Categorías Clave:

- **Application Logs:** Eventos de aplicaciones de usuario (ej. IIS, MS SQL).
- **Security Logs:** Nuestro foco. Eventos de seguridad como logins, creación de procesos y gestión de usuarios.



Capa 1: Logs Nativos de Seguridad

¿Quién ha intentado acceder al sistema?

Dentro de los más de 500 IDs de eventos de seguridad, dos son críticos para la autenticación.
Se registran en la máquina de destino (a la que se intenta acceder).



Event ID 4624 - Logueo Exitoso

Uso:

Detectar inicios de sesión RDP/red sospechosos e identificar el punto de entrada del ataque.

Advertencia:

🚩 Es muy 'ruidoso'. Puede generar cientos de eventos por minuto en servidores activos.



Event ID 4625 - Logueo Fallido

Uso:

Detectar ataques de fuerza bruta, password spraying o escaneo de vulnerabilidades.

Advertencia:

🚩 Es 'inconsistente'. Sus particularidades pueden llevar a malas interpretaciones.

Desglose del Event ID 4624: Las Pistas Clave

Logon Information (Tipo de Logueo): Un número que indica el método. ¡Esto es crucial!

10	RDP (Remote Desktop Protocol)
3	Red (Network)

Network Information: La IP y el **hostname** de origen. Fundamental para el triaje y la inteligencia de amenazas (CTI).

Subject
Subject ID:
Account Name:
Subject Name:

Logon Information
Número: 10

New Logon
Account Name
Account Domain
Logon ID

Process Information
Process Name
Process Domain

Network Information
Source Network Address
Workstation Name

Detailed Authentication Information
Account Name N/A
Event ID
Logon ID

New Logon: La cuenta y dominio que accedió. El **Logon ID** es un identificador único para esta sesión, vital para correlacionar eventos posteriores.

Caza de Amenazas: Detectando Ataques de Fuerza Bruta

Filtra en el Visor de Eventos por ID 4625 (fallos) y busca Tipos de Logueo 3 (Red) o 10 (RDP).



Múltiples Fallos en Cuentas Genéricas

Detalle:

Muchos intentos fallidos en usuarios como `admin`, `helpdesk`, o `cctv`.

Posible Amenaza:

Posible Amenaza:

Password Spraying.



Múltiples Fallos en una Sola Cuenta

Detalle:

Cientos de intentos fallidos en una cuenta específica, usualmente de administrador.

Posible Amenaza:

Posible Amenaza:

Ataque de Fuerza Bruta.



Origen Anómalo

Detalle:

El `Workstation Name` o la `IP de origen` no coinciden con los patrones esperados de la compañía.

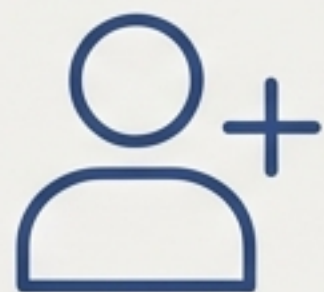
Posible Amenaza:

Posible Amenaza:

Acceso Externo no Autorizado.

¿Se han creado o modificado cuentas de usuario?

Los atacantes a menudo manipulan cuentas para mantener persistencia o escalar privilegios. Presta atención a estos eventos:



Creación / Habilitación

Event IDs: 4720, 4722, 4738
(Creación, Habilitación,
Cambio)

Attacker Tactic: Crear una cuenta *backdoor* o habilitar una antigua para pasar desapercibido.



Añadir a Grupos Privilegiados

Event IDs: 4732, 4733
(Añadido/Eliminado de grupo)

Táctica Tactic: Añadir su *backdoor* a grupos como “**Administradores**” para obtener control total.



Deshabilitación / Eliminación

Event IDs: 4725, 4726
(Deshabilitación,
Eliminación)

Táctica Tactic: Deshabilitar cuentas del equipo de seguridad para ralentizar la respuesta.

Caza de Amenazas: Descubriendo Cuentas Backdoor

Los atacantes a menudo manipulan cuentas para mantener persistencia. Sigue estos pasos para detectar actividades sospechosas.

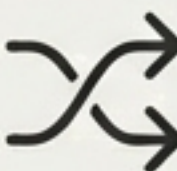
Metodología



1. **Filtrar:** Busca en los logs de seguridad los Event IDs `4720` (Creación de usuario) y `4732` (Usuario añadido a grupo).



2. **Investigar:** Revisa manualmente los eventos buscando estas señales de alerta.



3. **Correlacionar:** Si una acción es maliciosa, copia el `Logon ID` del **Sujeto** y búscalo en los eventos de autenticación (`4624`) para encontrar el origen del ataque.



El cambio se realizó fuera del horario laboral o sin notificación del equipo de TI.



El nombre de la cuenta que realizó la acción (**Sujeto**) es anómalo (ej: `adm.old.2008`).



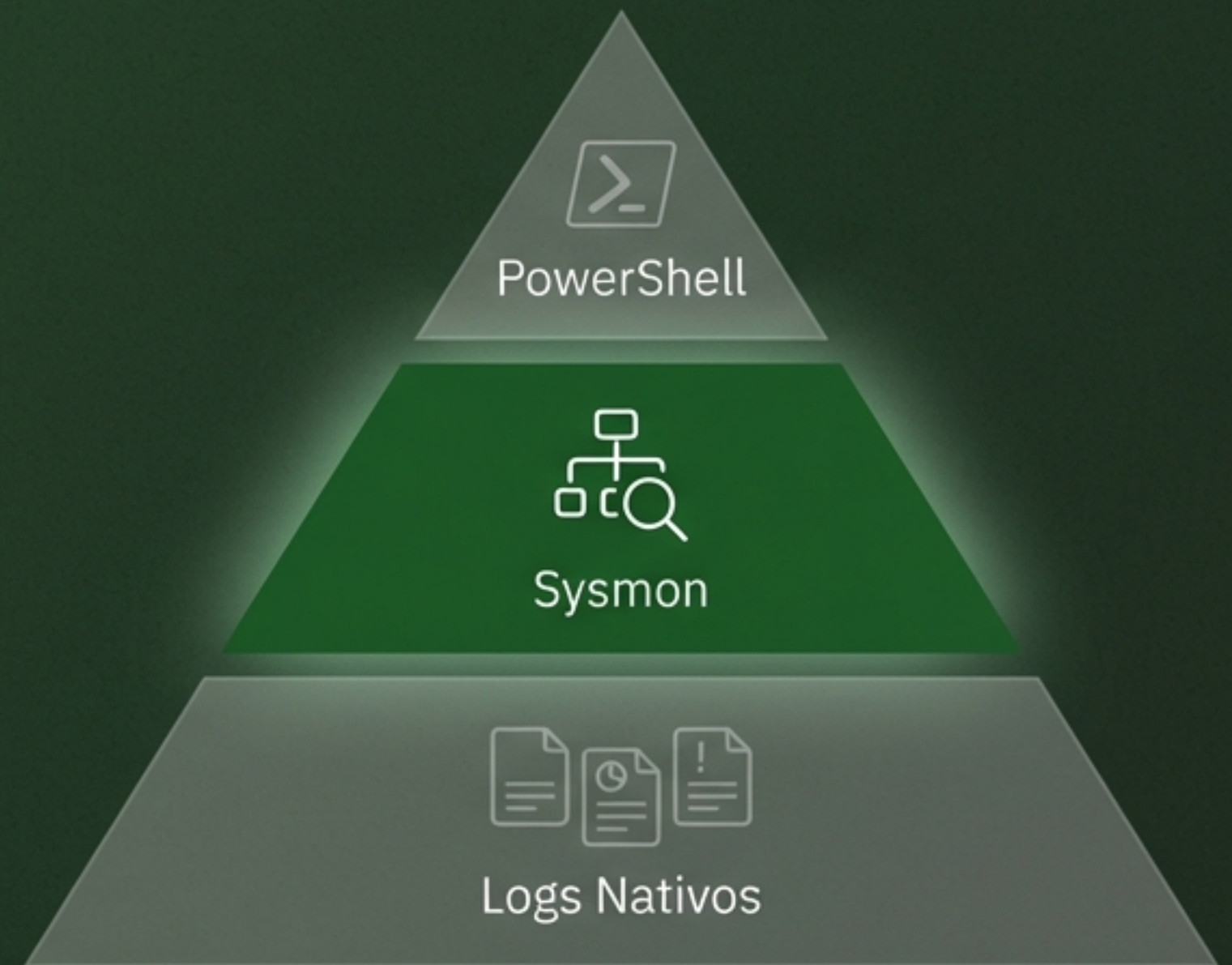
El nombre de la nueva cuenta (**Objeto**) no sigue el patrón de nombramiento de la empresa (ej: `backup` en lugar de `thm\_svc\_backup`).

**Sabemos *quién* entró
y *qué* cuentas modificó.**

*Pero, ¿qué hizo exactamente
una vez dentro?*

Para ver la creación de procesos, los logs
nativos no son suficientes por defecto.
Necesitamos una capa de visibilidad más
profunda. Necesitamos **Sysmon**.

Pirámide de Visibilidad



Capa 2: Sysmon - El Microscopio del Sistema

Sysmon (System Monitor) es una herramienta gratuita de Microsoft (Sysinternals) que registra la actividad del sistema con un detalle inmenso. Sus logs se encuentran en `Applications & Services -> Microsoft -> Windows -> Sysmon -> Operational`.

Log Nativo (Windows)	Monitoreo Avanzado (Sysmon)
Event ID 4688 Registra la creación de un proceso.	Event ID 1 Reemplaza y mejora el 4688.
✗ Deshabilitado por defecto. ○ Información básica (nombre del proceso, línea de comandos). ○ .	✓ Hash del Proceso (MD5, SHA256): Permite verificar contra bases de datos de malware. ✓ Firma Digital: Valida la legitimidad del ejecutable. ✓ Información del Padre: Crucial para construir el árbol de procesos.

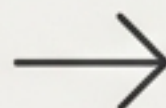
Caza de Amenazas: Analizando la Creación de Procesos (Sysmon ID 1)

Al revisar un evento de Sysmon ID 1, examina estos campos en busca de anomalías.

Paso 1: Analizar el Proceso Hijo

Red Flags:

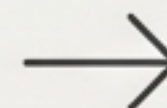
- `Image` (ruta) está en un directorio inusual (`C:\Temp`, `C:\Users\Public`).
- El nombre del proceso es sospechoso (`aa.exe`, `jqyvpqldou.exe`).
- El `Hash` coincide con malware conocido en VirusTotal.



Paso 2: Analizar el Proceso Padre

Red Flags:

- El proceso padre no es el esperado (ej: `Notepad.exe` lanzando `cmd.exe`).
- El proceso padre también tiene una ruta, nombre o hash sospechoso.



Paso 3: Trazar la Cadena Completa

Acción: Filtra todos los eventos (Seguridad y Sysmon) que compartan el mismo `Logon ID` para reconstruir toda la sesión del atacante.

Más Allá de los Procesos: Red, Archivos y Registro con Sysmon

Sysmon ofrece visibilidad sobre las acciones clave de un atacante post-explotación.



Comunicaciones y Exfiltración

Event ID 3: Conexión de Red

Event ID 22: Consulta DNS

- ✓ **Utilidad:** Detectar tráfico hacia destinos maliciosos (C2) o conexiones a puertos inusuales (ej. 4444). Correlaciona el `ProcessId` con un evento ID 1 para saber *qué proceso* hizo la conexión.

 **Red Flag:** Un proceso no confiable conectándose a una IP externa desconocida o a un dominio sospechoso.



Persistencia y Despliegue de Malware

Event ID 11: Creación de Archivo

Event ID 13: Modificación de Valor en el Registro

- ✓ **Utilidad:** Ver si un atacante deja un archivo malicioso (script, ejecutable) o modifica el registro para asegurar su persistencia tras un reinicio.

 **Red Flag:** Un archivo ejecutable creado en `C:\Temp` o una clave de registro de auto-arranque modificada.

Sysmon nos muestra que 'powershell.exe' se ejecutó.

Pero, ¿qué comandos se ejecutaron
dentro de esa sesión?

PowerShell es una herramienta 'todo en uno'.
Un atacante puede ejecutar cientos de comandos
maliciosos dentro de un único proceso
powershell.exe, haciéndolos invisibles para el
Event ID 1. Necesitamos la capa final de visibilidad.

Pirámide de Visibilidad



Capa 3: Descifrando los Comandos de PowerShell

Los atacantes abusan de PowerShell para descarga de malware, reconocimiento y exfiltración, todo dentro de una misma sesión.

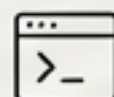


Una Pista Fundamental: El Historial de Comandos

Ubicación: `C:\Users\
<USER>\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt`

Propiedades Clave:

- Se crea un archivo por cada usuario.
- Sobrevive a reinicios del sistema (a menos que se borre).
- Registra todos los comandos introducidos, indefinidamente.



Limitaciones Críticas (y por qué necesitas más):

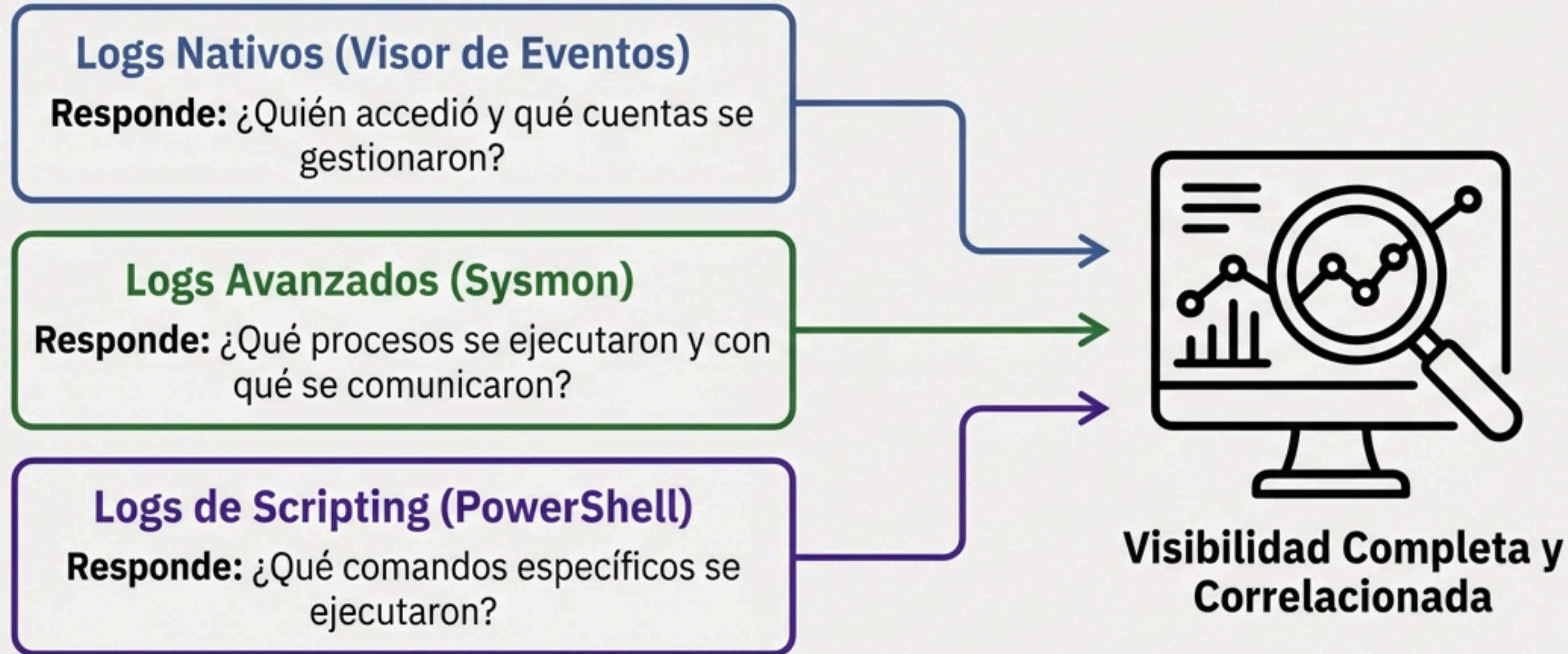
- ❗ No registra **la salida** de los comandos.
- ❗ No muestra el **contenido de los scripts** ejecutados (ej. `powershell .\script.ps1`).



Nota: Para una visibilidad completa, se requiere habilitar políticas avanzadas como la transcripción de sesiones y el registro detallado de módulos vía GPO.

Construyendo una Defensa en Profundidad

Un monitoreo efectivo en Windows no depende de una sola fuente, sino de la correlación de múltiples capas de visibilidad. Cada capa responde a preguntas más profundas sobre la actividad en el sistema.



Combina estas fuentes en tu SIEM para obtener una imagen clara del estado de seguridad, responder con rapidez y fortalecer tu postura defensiva.